



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Microsoft Passkey-Themed Social Engineering and Identity Compromise Daily Update

Threat Report

Classification	TLP:CLEAR
Published	2026-09-20
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | Microsoft Passkey-Themed Social Engineering and Identity Compromise Daily Update - Threat Report

Published: 2026-09-20 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Activity Overview
5. Affected Sectors and Exposure
6. Tactics, Techniques, and Procedures
7. Infrastructure and Indicators
8. Detection Engineering
 - 8.1. Detection Summary
 - 8.2. Sigma / Detection Content
 - 8.3. Hunt Query
9. Threat Hunting
 - 9.1. Hunt Hypothesis
 - 9.2. Hunt Query
 - 9.3. Cloud/API Hunt Query
10. Risk Assessment
11. Recommended Actions
12. References

Microsoft Passkey-Themed Social Engineering and Identity Compromise Daily Update

1. Executive Summary

Microsoft reported passkey-themed social engineering that leads to identity and cloud compromise, including MFA persistence and Microsoft Graph reconnaissance. Defenders should treat user-facing authentication transitions as a live social-engineering surface and instrument Entra ID, OAuth app consent, risky sign-ins, and unusual Graph access.

This report is a 2026-09-20 daily update built for current analyst review. It preserves source limitations: it does not invent IOCs or attribution beyond the cited reporting, and it uses detection logic to operationalize behaviors defenders can validate in their own telemetry.

2. Intelligence Requirements

Question	Current Answer	Confidence
What should defenders prioritize today?	Validate exposure, harden identity/API paths, and hunt for behavior-level signals tied to the reporting.	High
Are hard IOCs available?	Not consistently across all public sources; this report emphasizes telemetry and behavior hunts.	Medium
Which teams should act?	SOC, IAM, vulnerability management, cloud/security engineering, and sector system owners.	Medium

3. Source Review & Confidence

Source	Contribution	Confidence
Microsoft passkey-themed social engineering report	https://www.microsoft.com/en-us/security/blog/2026/09/09/passkey-themed-social-engineering-leads-identity-cloud-compromise/	Medium/High
Microsoft identity attack detection guidance	https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-overview	Medium/High
CISA phishing guidance	https://www.cisa.gov/resources-tools/resources/phishing-guidance-stopping-attack-cycle-beginning	Medium/High

4. Threat Activity Overview

Microsoft reported passkey-themed social engineering that leads to identity and cloud compromise, including MFA persistence and Microsoft Graph reconnaissance. Defenders should treat user-facing authentication transitions as a live social-engineering surface and instrument Entra ID, OAuth app consent, risky sign-ins, and unusual Graph access.

5. Affected Sectors and Exposure

Sector / Environment	Exposure Relevance
Enterprise identity and cloud tenants	Credential, OAuth, API, and administrative telemetry are often

	where activity first appears.
Endpoint and browser fleets	User-executed lures, fake installers, scripts, and remote tools require endpoint visibility.
Third-party service providers	Shared administrative paths can multiply impact across clients and operational environments.

6. Tactics, Techniques, and Procedures

Tactic / Phase	Observed Technique	Evidence
T1566	Phishing	Used as defensive mapping for the reported behavior.
T1098	Account Manipulation	Used as defensive mapping for the reported behavior.
T1078	Valid Accounts	Used as defensive mapping for the reported behavior.
T1528	Steal Application Access Token	Used as defensive mapping for the reported behavior.

7. Infrastructure and Indicators

Indicator / Infrastructure	Type	Operational Use
No durable public IOC set validated in this automated run	Source limitation	Use behavior-based hunts and add IOCs only after analyst validation.
Lookalike domains, newly seen OAuth apps, unusual API clients	Observable class	Common places to find related activity without overfitting to stale IOCs.

8. Detection Engineering

8.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
New OAuth consent, MFA method, or passkey changes near risky sign-in	Entra ID / identity logs	Detect account takeover and persistence.
Browser download or script execution from AI-themed/search-result lures	EDR / proxy / DNS	Detect social-engineering execution chains.
Unusual API-token use or high-volume AI/API access	Cloud/API gateway logs	Detect credential theft or model/API abuse.

8.2. Sigma / Detection Content

<pre> title: Suspicious Identity Persistence or AI-Themed Lure Activity status: experimental description: Behavior-level rule for daily CTI operationalization; tune field names to local SIEM schema. logsource: product: azure service: signinlogs </pre>

```

detection:
  selection:
    Operation|contains:
      - 'Add authentication method'
      - 'Consent to application'
      - 'Update application'
  timeframe: 1h
  condition: selection
  level: high

```

8.3. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(14d)
| where ProcessCommandLine has_any
('copilot', 'chatgpt', 'claude', 'deepseek', 'passkey', 'mfa', 'oauth', 'token')
or FileName in~ ('powershell.exe', 'wscript.exe', 'cscript.exe', 'mshta.exe', 'rundll32.exe')
| summarize Events=count(), Devices=dcount(DeviceName), Users=dcount(InitiatingProcessAccountName) by
FileName, ProcessCommandLine
| order by Events desc

```

9. Threat Hunting

9.1. Hunt Hypothesis

Threat activity related to this item is more likely to surface as identity, endpoint, browser, cloud, or API anomalies than as a stable IOC list.

9.2. Hunt Query

```

SigninLogs
| where TimeGenerated > ago(14d)
| where ResultType == 0
| where AppDisplayName has_any ('Graph', 'Office 365', 'Azure', 'Copilot') or UserAgent has_any
('python', 'curl', 'node', 'go-http')
| summarize Signins=count(), IPs=make_set(IPAddress, 20), Apps=make_set(AppDisplayName, 20) by
UserPrincipalName
| where Signins > 10 or array_length(IPs) > 5

```

9.3. Cloud/API Hunt Query

```

CloudAppEvents
| where Timestamp > ago(14d)
| where ActionType has_any ('Consent to application', 'Add service principal', 'Add owner to
application', 'Create API key', 'Update application')
| project Timestamp, AccountDisplayName, ActionType, Application, IPAddress, RawEventData

```

10. Risk Assessment

Dimension	Assessment
Likelihood	High for exposed organizations matching the described behaviors.
Impact	Credential theft, persistence, data access, operational disruption, or intellectual-property loss depending on environment.
Confidence	High; source limitations are recorded above.

11. Recommended Actions

Priority	Owner	Action
Critical	SOC	Run the included hunts and tune to known admin/tooling baselines.

High	IAM	Enforce phishing-resistant MFA, review new MFA/passkey methods, and restrict OAuth consent.
High	Cloud/API owners	Inventory API keys, service principals, AI-service access, and abnormal usage spikes.
Medium	Vendor management	Confirm third-party access controls and incident notification paths.

12. References

- [1] Microsoft passkey-themed social engineering report: <https://www.microsoft.com/en-us/security/blog/2026/09/09/passkey-themed-social-engineering-leads-identity-cloud-compromise/>
- [2] Microsoft identity attack detection guidance: <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-overview>
- [3] CISA phishing guidance: <https://www.cisa.gov/resources-tools/resources/phishing-guidance-stopping-attack-cycle-beginning>